

Solution Recommendation MFA for PACER

Version 1.3

November 2023

Prepared By Technology Solution Office (TSO), Enterprise Architecture Group (EA)
Administrative Office (AO) of the U.S. Courts

Revision History

Version	Date	Description	A = Add M = Modify D = Delete	Author / Office
1.0.	09/05/2023	Initial draft complete	New	Alec Gura, Muhammad Nazir
1.0.	09/19/2023	Peer Review	U	Sunil Bandapally
1.1.	10/23/2023	Group Review	A, M	Alec Gura, Muhammad Nazir, Sunil Bandapally, Lauryn Holcomb
1.2	11/06/2023	Fixing MFA standup review	U	Alec Gura, Muhammad Nazir, Sunil Bandapally, Lauryn Holcomb
1.3	11/09/2023	Producing final version for approval	A, M, U	Alec Gura, Muhammad Nazir, Sunil Bandapally, Lauryn Holcomb

Table of Contents

REVISION HISTORY	2
LIST OF ABBREVIATIONS	4
1.0. INTRODUCTION	5
2.0. COURT SERVICES OFFICE (CSO) BUSINESS REQUIREMENTS	5
3.0. PROPOSED SOLUTIONS.....	5
3.1. OPEN TIME-BASED ONE TIME PASSWORD	6
3.2. INHOUSE PLATFORM LEVEL API GATEWAY SOLUTION	7
4.0. SOLUTION EVALUATION	8
4.1. SOLUTION EVALUATION CHART	8
5.0. SOLUTION RECOMMENDATION	9
.....	
7.0. CONCLUSION	12
8.0. REFERENCES	12
9.0. APPENDIX A	13
9.1. REFERENCE IMPLEMENTATION LIBRARIES FOR PACER	13
10.0. APPENDIX B.....	14
10.1. AUTHENTICATION ASSURANCE LEVEL 2 REQUIREMENTS (NIST800-63B)	14
10.2. RISK IMPACTS (NIST800-63-3)	15

List of Abbreviations

TSO – Technology Solution Office
EA – Enterprise Architecture
AO – Administrative Office
MFA – Multi-Factor Authentication
PACER – Public Access to Court Electronic Records
CSO – Court Services Office
CM – Case Management
ECF – Electronic Case Files
API – Application Programming Interface
HOTP – HMAC Based One-Time Password
U2F – Universal Second Factor
TOTP – Open Time-Based One-Time Password
USB – Universal Serial Bus
NFC – Near-Field Communication
OTP – One-Time Password
HMAC – Hash-Based Message Authentication Code
SMS – Short Message Service
SQL – Structured Query Language
ACL – Access Control List
AES – Advanced Encryption Standard
JISF – Judiciary Information & Security Framework standards

1.0. Introduction

The purpose of this document is to recommend a solution for integrating Multi-Factor Authentication (MFA) into the Public Access to Court Electronic Records (PACER) system to improve filer security and support opt-in MFA for non-filers while not changing the existing user identities and credentials store.

2.0. Court Services Office (CSO) Business Requirements

1. Public users shall continue using their PACER account to authenticate with multi-factor authentication enabled if they are in the required category.
2. Public users with PACER accounts that have Case Management (CM)/Electronic Case Files (ECF) level access privileges (meaning beyond read-only access) will be required to use multi-factor authentication (MFA) when accessing CM/ECF via the PACER portal (user interface or Application Programming Interface (API)).
 - a. These users will not have the ability to opt out of MFA unless an exception has been made for them.
 - b. Exception will be made for users where MFA becomes a barrier to access to the courts (e.g., user may not have access to devices).
 - c. Mechanism needs to be available for AO staff to be able to remove users from the required category.
3. Public users with read-only access shall have the ability to opt in via a user interface.
 - a. These users should be able to opt into MFA using Manage My Account to ensure a continued cohesive user experience.
4. MFA solution will provide a variety of MFA methods for users to select from.
5. MFA solution should provide a way for users to update MFA settings in the event they lose access to device or applications.
6. MFA solution will be user-friendly and intuitive to use.
7. MFA solution will have high availability to ensure users are not prevented from accessing the system.
8. MFA solution will not require changes to CM/ECF.
9. MFA solution should not be cost prohibitive and should be sustainable for the foreseeable future.

3.0. Proposed Solutions

PACER's current constraints, which include customized authentication and user identities, limit the potential workable solutions. The TSO team reviewed the solutions listed below:

- HMAC Based One-Time Password (HOTP)
- Universal Second Factor (U2F)
- Open Time-Based One-Time Password (TOTP)
- Inhouse Platform Level API Gateway

TSO identified that HOTP and U2F were not viable options:

HOTP passwords are long-lived and remain active for an unknown amount of time until they are used for authentication. This makes them much less secure.

U2F is an open standard that strengthens and simplifies Two-Factor Authentication (2FA) using specialized Universal Serial Bus (USB) or Near-Field Communication

(NFC) devices. Providing physical devices to individual public users is not practical or cost-effective.

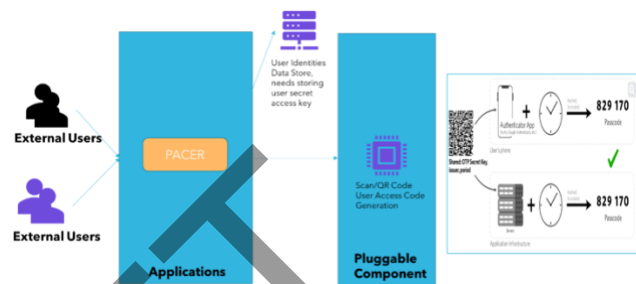
TSO determined that viable solutions would be:

Open Time-Based One Time Password and an
Inhouse Platform Level API Gateway Solution.

The subsequent sections will detail each option's specifics, advantages, and challenges.

3.1. Open Time-Based One Time Password

TOTP is a security algorithm used for two-factor authentication and it generates a temporary One-Time Password (OTP) every 30 or 60 seconds ([RFC 6238](#)). TOTP-compatible authenticator apps generate unique time-limited passwords to secure authentication.



Open TOTP means any standards compliant TOTP vendor can be used on the client side to create the temporary passwords. Open TOTP is not locked to a single provider.

TOTP can be configured with any compliant authenticator apps in the market with the caveat that the app can process the protocols associated with TOTP. Some industry-leading apps include Microsoft Authenticator App, Google Authenticator, Authy, and DUO.

Advantages:

- Strong security: Provides robust two-factor authentication.
- Time-bound: Passwords expire quickly, reducing the window for attacks.
- Offline use: Devices to retrieve TOTP do not require an internet connection to generate a One-Time Password, once it is set up.
- Widely supported: Compatible with various apps and devices.

Disadvantages:

- Dependency on clock synchronization: Devices must maintain accurate time.
- Setup complexity: Initial setup can be challenging for some users.
- No generator recovery: This can be problematic if a user loses access to the generator.

High-Level Implementation:

- TOTP Implementation: Implement the TOTP algorithm in PACER authentication system. This involves generating TOTP codes based on a user secret key, also called the 'shared secret' (generated unique per user), and the current time.
- User Interface: Design and develop a user interface within PACER application to allow users to enable and configure TOTP. Ideally, this interface should provide users options to scan a generated QR code into any compatible Authenticator app.
- QR Code or Secret Key Generation: Generate a unique secret key for each user during setup that will be used to generate TOTP codes. Also, create a QR code containing the secret key and necessary information for any compatible Authenticator to recognize and enroll the user.

- **Secret Key Delivery:** The QR code and secret key will be displayed, one time, to the user in the web interface, where the user can scan the QR code with the authenticator application or input the secret key manually in the authenticator application.
- **Secret Key Storage:** The generated secret key must be stored securely within PACER identity store, either encrypted or in a secure key storage vault.
- **User Account Management:** Update PACER user account management system to securely store and associate the user's TOTP secret key. This information must be linked to the user's account to verify TOTP codes during the login process.
- **Integration with Authenticator app:** Provide instructions or user guides on installation and usage of an Authenticator app. Explain the QR code scanning process within the app to set up TOTP for the PACER user.

3.2. Inhouse Platform Level API Gateway Solution

Platform-level API Gateway is a custom-built solution with the rules and infrastructure for scaling to PACER peak demand. This includes building and implementing an in-house API based solution leveraging Hash-Based Message Authentication Code algorithm.

This solution requires new development of APIs integrating with existing PACER user identities store and an email and Short Message Service (SMS) transmit service.

Advantages:

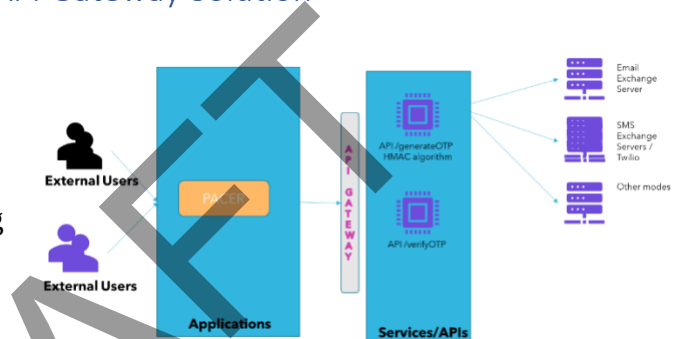
- Pure inhouse solution, does not require any client software.
- Reporting and stats can be easily gathered as the data store is inhouse.
- The platform/enterprise-level APIs can be extended to other applications and use cases in need of OTP kind of security.
- API Gateway provides required security against common threats like Phishing, Structured Query Language (SQL) Injections, etc.

Disadvantages:

- Requires considerable amount of time, resources, and budget for building the solution.
- Requires new infrastructure for hosting APIs, data storage for OTP, mail communication, and for SMS.

High Level Implementation:

- API to generate OTP, based on prescribed set of parameters unique to the application request like requested correlation, user session id, etc., generate a six-digit OTP using HMAC algorithm.
- API to verify OTP, verify if the user is sending the OTP generated and passed.



4.0. Solution Evaluation

The solution evaluation chart provided below summarizes the requirements and considerations related to the MFA solution for PACER. The chart evaluates the proposed solutions against the CSO requirements.

4.1. Solution Evaluation Chart

#	CSO Requirement	TOTP supported?	API Gateway supported?	Needs PACER Custom Build
1	Public users shall continue using their PACER account to authenticate with multi-factor authentication enabled if they are in the required category.	Yes	Yes	No
2	Public users with PACER accounts that have CM/ECF level access privileges (meaning beyond read-only access) will be required to use multi-factor authentication (MFA) when accessing CM/ECF via the PACER portal (user interface or API).	No	No	Yes, for user interface but MFA for APIs is not feasible.
2.a	These users will not have the ability to opt out of MFA unless an exception has been made for them.	No	No	Yes
2.b	Exception will be made for users where MFA becomes a barrier to access to the courts (e.g., user may not have access to devices).	No	No	Yes
2.c	Mechanism needs to be available for AO staff to be able to remove users from the required category.	No	No	Yes
3	Public users with read-only access, these users	No	No	Yes

#	CSO Requirement	TOTP supported?	API Gateway supported?	Needs PACER Custom Build
	should be able to opt into MFA using Manage My Account to ensure a continued cohesive user experience. 3.a These users should be able to opt into MFA using Manage My Account to ensure a continued cohesive user experience.			
4	MFA solution will provide a variety of MFA methods for users to select from.	Yes (at least one)	Yes (multiple)	No
5	MFA solution should provide a way for users to update MFA settings in the event they lose access to device or applications.	No	No	Yes
6	MFA solution will be user-friendly and intuitive to use.	Yes	Yes	No
7	MFA solution will have high availability to ensure users are not prevented from accessing the system.	Yes	Yes	No
8	MFA solution will not require changes to CM/ECF.	Yes	Yes	No
9	MFA Solution should not be cost prohibitive and should be sustainable for the foreseeable future.	Yes	No, API solution requires considerable development	No

5.0. Solution Recommendation

Two authentication solutions, open TOTP and API/Gateway, were considered for implementation. After evaluation, open TOTP is recommended as the preferred authentication method for PACER due to several factors:

- **Ease of Implementation:** TOTP is relatively straightforward to implement, making it an attractive choice for quick deployment. It relies on a shared secret and a time-based algorithm to generate one-time passwords, simplifying the development process.
- **Familiarity with TOTP:** The PACER development team already possesses knowledge and experience with TOTP authentication. Leveraging this familiarity reduces the learning curve and accelerates the implementation process.
- **Security:** TOTP offers a high level of security, as it generates unique passwords that expire after a short period. This helps mitigate the risk of unauthorized access and enhances overall system security.
- **User-Friendly:** TOTP is user-friendly, with many authenticator apps available for various platforms. Users can easily set up TOTP on their devices, making it a convenient choice for end-users.
- **Cost-Effective:** TOTP authentication requires minimal infrastructure and does not incur additional costs for API or gateway services.

The API Gateway solution takes time to build and implement, has infrastructure expenses, and require services such as SMS and e-mail. Based on the evaluation above, the TSO recommend using the open TOTP solution for PACER.

DRAFT

LEFT INTENTIONALLY BLANK

DRAFT

7.0. Conclusion

In conclusion, Open TOTP authentication is the TSO recommended solution due to its ease of implementation, the development team's familiarity with it, its strong security features, user-friendliness, and cost-effectiveness. This choice closely aligns with the project's requirements.

8.0. References

- 2020, Irma T. Plata, Jomar L. Calpito , <https://www.ijstr.org/final-print/mar2020/Application-Of-Time-based-One-Time-Password-totp-Algorithm-For-Human-Resource-E-leave-Tracking-Web-App.pdf>
- 2023, Paul A Grassi, NIST Special Publication 800-63B, Digital Identity Guidelines Authentication and Lifecycle Management, <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-63b.pdf>
- 2022, Keeper, <https://docs.keeper.io/user-guides/tips-and-tricks/using-keeper-totp-with-office-365>
- 2023, Google Cloud Documentation, <https://cloud.google.com/identity-platform/docs/admin/enabling-totp-mfa>
- 2023, JISF Security Standards, <https://jnet.ao.dcn/information-technology/security/framework-shp/judiciary-info-sec-framework>
- 2023, User Authentication, Third party two factor authenticator applications, https://jnet.ao.dcn/sites/default/files/pdf/user_authentication_applications.pdf
- 2011, TOTP: Time-Based One-Time Password Algorithm, RFC 6238: <https://datatracker.ietf.org/doc/html/rfc6238>

³ NIST-SP 800-63B, pages.nist.gov/800-63-3/sp800-63b.html

⁴ FIPS140-3, [Federal Information Processing Standards Publication 140-3](https://nvlpubs.nist.gov/nistpubs/fips/nist.fips.140-3.pdf)

9.0. Appendix A

9.1. Reference Implementation Libraries for PACER

- dotNET
 - <https://www.nuget.org/packages/OtpSharp> - This library can generate and verify both TOTP and HOTP authentication codes. The calculations in this library are known to be compatible with Google 2-Step Verification and consequently the Google Authenticator smartphone app.
- Java
 - <https://github.com/wstrange/GoogleAuth> - GoogleAuth is a Java server library that implements the Time-based One-time Password (TOTP) algorithm specified in RFC 6238.
- Rails
 - <https://github.com/jeremyevans/rodauth> - Rodauth is Ruby's most advanced authentication framework, designed to work in any rack application. It is built using Roda and Sequel, but it can be used with other web frameworks, database libraries, and databases. Rodauth supports multiple multifactor authentication methods, multiple passwordless authentication methods and offers both an HTML and JSON API for all supported features.

10.0. Appendix B

10.1. Authentication Assurance Level 2 Requirements (NIST800-63B)

NIST 800-63B Requirement	Authenticator Assurance Level (AAL) 2
Permitted authenticator types	MF OTP Device; MF Crypto Software; MF Crypto Device; or Memorized Secret plus: • Look-up Secret • Out-of-Band • SF OTP Device • SF Crypto Software • SF Crypto Device
FIPS 140 validation	Level 1 (Government agency authenticators and verifiers)
Reauthentication	12 hours or 30 minutes inactivity; MAY use one authentication factor
Security controls	SP 800-53 Moderate Baseline or equivalent
MitM resistance	Required
Verifier-impersonation resistance	Not required
Verifier-compromise resistance	Not required
Replay resistance	Required
Authentication intent	Recommended
Records Retention Policy	Required
Privacy Controls	Required

10.2. Risk Impacts (NIST800-63-3)

Potential impact of inconvenience, distress, or damage to standing or reputation:

- Low: at worst, limited, short-term inconvenience, distress, or embarrassment to any party.
- Moderate: at worst, serious short-term or limited long-term inconvenience, distress, or damage to the standing or reputation of any party.
- High: severe or serious long-term inconvenience, distress, or damage to the standing or reputation of any party. This is ordinarily reserved for situations with particularly severe effects or which potentially affect many individuals.

Potential impact of financial loss:

- Low: at worst, an insignificant or inconsequential financial loss to any party, or at worst, an insignificant or inconsequential agency liability.
- Moderate: at worst, a serious financial loss to any party, or a serious agency liability.
- High: severe or catastrophic financial loss to any party, or severe or catastrophic agency liability.

Potential impact of harm to agency programs or public interests:

- Low: at worst, a limited adverse effect on organizational operations or assets, or public interests. Examples of limited adverse effects are: (i) mission capability degradation to the extent and duration that the organization is able to perform its primary functions with noticeably reduced effectiveness, or (ii) minor damage to organizational assets or public interests.
- Moderate: at worst, a serious adverse effect on organizational operations or assets, or public interests. Examples of serious adverse effects are: (i) significant mission capability degradation to the extent and duration that the organization is able to perform its primary functions with significantly reduced effectiveness; or (ii) significant damage to organizational assets or public interests.
- High: a severe or catastrophic adverse effect on organizational operations or assets, or public interests. Examples of severe or catastrophic effects are: (i) severe mission capability degradation or loss of to the extent and duration that the organization is unable to perform one or more of its primary functions; or (ii) major damage to organizational assets or public interests.

Potential impact of unauthorized release of sensitive information:

- Low: at worst, a limited release of personal, U.S. government sensitive, or commercially sensitive information to unauthorized parties resulting in a loss of confidentiality with a low impact as defined in FIPS 199.
- Moderate: at worst, a release of personal, U.S. government sensitive, or commercially sensitive information to unauthorized parties resulting in loss of confidentiality with a moderate impact as defined in FIPS 199.
- High: a release of personal, U.S. government sensitive, or commercially sensitive information to unauthorized parties resulting in loss of confidentiality with a high impact as defined in FIPS 199.

Potential impact to personal safety:

- Low: at worst, minor injury not requiring medical treatment.
- Moderate: at worst, moderate risk of minor injury or limited risk of injury requiring medical treatment.

- High: a risk of serious injury or death.

The potential impact of civil or criminal violations is:

- Low: at worst, a risk of civil or criminal violations of a nature that would not ordinarily be subject to enforcement efforts.
- Moderate: at worst, a risk of civil or criminal violations that may be subject to enforcement efforts.
- High: a risk of civil or criminal violations that are of special importance to enforcement programs.

DRAFT